Practice Questions

Candidate: Dunkan Gibson (dunkan.gibson)
Date: 11/20/2021 9:01:24 pm • Time spent: 03:31

Score: 80% Passing Score: 80%

Question 1: ✔ Correct

Which of the following uses hacking techniques to proactively discover internal vulnerabilities?

- Passive reconnaissance
- Inbound scanning
- ➡ Penetration testing
- Reverse engineering

EXPLANATION

Penetration testing is the practice of proactively testing systems and policies for vulnerabilities. This approach seeks to identify vulnerabilities internally before a malicious individual can take advantage of them. Common techniques are identical to those used by hackers and include network/target enumeration and port scanning.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 2: ✔ Correct

What is the main difference between vulnerability scanning and penetration testing?

- Vulnerability scanning is performed with a detailed knowledge of the system; penetration testing starts with no knowledge of the system.
- ➡ Vulnerability scanning is performed within the security perimeter; penetration testing is performed outside of the security perimeter.
- Vulnerability scanning uses approved methods and tools; penetration testing uses hacking tools.
- The goal of vulnerability scanning is to identify potential weaknesses; the goal of penetration testing is to attack a system.

EXPLANATION

Penetration testing simulates an actual attack on the network and is conducted from outside the organization's security perimeter. Vulnerability scanning is typically performed internally by users with administrative access to the system.

The goal of both vulnerability scanning and penetration testing is to identify the effectiveness of security measures and identify weaknesses that can be fixed. While some penetration testing is performed with no knowledge of the network, penetration testing could be performed by testers with detailed information about the systems. Both vulnerability scanning and penetration testing can use similar tools, although illegal tools should be avoided in both activities.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 3: ✔ Correct

What is the primary purpose of penetration testing?

- Assess the skill level of new IT security staff.
- Infiltrate a competitor's network.
- Evaluate newly deployed firewalls.
- ➡ Test the effectiveness of your security perimeter.

EXPLANATION

The primary purpose of penetration testing is to test the effectiveness of your security perimeter. Only by attempting to break into your own secured network can you be assured that your security policy, security mechanism implementations, and deployed countermeasures are effective. It is important to obtain senior management approval before starting a penetration testing or vulnerability scanning project. Often, penetration testing or vulnerability scanning is performed by an external consultant or security outsourcing agency that is hired by your organization.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 4: ✔ Correct

You have decided to perform a double-blind penetration test. Which of the following actions should you perform first?

- Engage in social engineering.
- Run system fingerprinting software.
- Perform operational reconnaissance.
- ➡ Inform senior management.

EXPLANATION

Before starting a penetration test (also called a pen test) it is important to define the rules of engagement (ROE), or the boundaries of the test. Important actions to take include:

- Obtain a written and signed authorization from the highest possible senior management.
- Delegate personnel who are experts in the areas being tested.
- Gain approval from the internet provider to perform the penetration test.
- Make sure that all tools or programs used in the testing are legal and ethical.
- Establish the scope and timeline.
- Identify systems that will not be included in the test.

Performing reconnaissance, social engineering, or system scanning are all actions performed during a penetration test. However, no actions should be taken before approval to conduct the test is obtained.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 5: ✔ Correct

Which of the following activities are typically associated with a penetration test? (Select two.)

- [x] Attempting social engineering
- [ ] Creating a performance baseline
- [x] Running a port scanner
- [ ] Running a vulnerability scanner on network servers
- [ ] Interviewing employees to verify the security policy is being followed

EXPLANATION

Penetration testing is when an organization attempts to circumvent security controls to identify vulnerabilities in their information systems. It simulates an actual attack on the network and is conducted from outside the organization's security perimeter. Penetration testing helps assure the effectiveness of an organization's security policy, security mechanism implementations, and deployed countermeasures.

Penetration testing typically uses tools and methods that are available to attackers. Penetration testing might start with attempts at social engineering or other reconnaissance activities followed by more active scans of systems and then actual attempts to access secure systems.

A vulnerability scanner checks a system for weaknesses. Vulnerability scanners typically require administrative access to a system and are performed internally to check for weaknesses, but not to test system security. Penetration testers are not typically able to run a vulnerability scanner unless they have been able to gain unauthorized access to a system.

A performance baseline is created by an administrator to identify normal network and system performance. Auditing might include interviewing employees to make sure that security policies are being followed.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 6: ✔ Correct

Which of the following types of penetration test teams will provide you information that is most revealing of a real-world hacker attack?

- Split knowledge team
- Full knowledge team
- ➡ Zero knowledge team
- Partial knowledge team

EXPLANATION

A zero knowledge team is the penetration testing team that most closely simulates a real-world hacker attack, as they must perform all of the initial blind reconnaissance.

A full knowledge team is least like a real-world hacker, as they already know everything about the environment. A partial knowledge team is closer to a real-world hacker than a full knowledge team, but not as close as a zero knowledge team. There is no standard name of a penetration testing team known as a split knowledge team. Split knowledge refers to a separation of duties concept.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 7: ✕ Incorrect

A security administrator is conducting a penetration test on a network. She connects a notebook system running Linux to the wireless network and then uses NMAP to probe various network hosts to see which operating system they are running.

Which process did the administrator use in the penetration test in this scenario?

- Passive fingerprinting
- Firewalking
- ➡ Active fingerprinting
- ~~Network enumeration~~

EXPLANATION

The administrator in this scenario used active fingerprinting. Active fingerprinting is a form of system enumeration that is designed to gain as much information about a specific computer as possible. It identifies operating systems based upon ICMP message quoting characteristics. Portions of an original ICMP request are repeated (or quoted) within the response, and each operating system quotes this information back in a slightly different manner. Active fingerprinting can determine the operating system and even the patch level.

Passive fingerprinting works in much the same manner as active fingerprinting. However, it does not utilize the active probes of specific systems. Network enumeration (also called network mapping) involves a thorough and systematic discovery of as much of the corporate network as possible, using:

- Social engineering
- Wardriving
- War dialing
- Banner grabbing
- Firewalking

Firewalking uses traceroute techniques to discover which services can pass through a firewall or a router. Hping and Firewalk are common firewalking tools.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 8: ✕ Incorrect

A security administrator is conducting a penetration test on a network. She connects a notebook system to a mirror port on a network switch. She then uses a packet sniffer to monitor network traffic to try and determine which operating systems are running on network hosts.

Which process did the administrator use in the penetration test in this scenario?

- ~~Network enumeration~~
- Passive fingerprinting
- Firewalking
- Active fingerprinting

EXPLANATION

The administrator in this scenario used passive fingerprinting. Passive fingerprinting is a form of system enumeration that is designed to gain as much information about network computers as possible. It passively listens to network traffic generated by network hosts and attempts to identify which operating systems are in use based upon the ICMP message quoting characteristics they use. Portions of original ICMP requests are repeated (or quoted) within each response. Each operating system quotes this information back in a slightly different manner.

Active fingerprinting works in much the same manner as passive fingerprinting. However, it utilizes active probes of specific systems instead of passive monitoring. Network enumeration (also called network mapping) involves a thorough and systematic discovery of as much of the corporate network as possible, using:

- Social engineering
- Wardriving
- War dialing
- Banner grabbing
- Firewalking

Firewalking uses traceroute techniques to discover which services can pass through a firewall or a router. Hping and Firewalk are common firewalking tools.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 9: ✔ Correct

Drag each penetration test characteristic on the left to the appropriate penetration test name on the right.

White box test	Grey box test	Black box test
✔ The tester has detailed information	✔ The tester has the same amount of information that would be available to a typical insider in the organization.	✔ The tester has no prior knowledge of the target system.
Single-blind test	Double-blind test	
✔ Either the attacker has prior knowledge about the target system or the administrator knows that the test is being performed.	✔ The tester does not have prior knowledge about the system, and the administrator has no knowledge that the test is being performed.	

EXPLANATION

Penetration testing is classified by the knowledge that the attacker and system personnel have prior to the attack.

- In a black box test, the tester has no prior knowledge of the target system.
- In a white box test, the tester has detailed information prior to starting the test.
- In a grey box test, the tester has the same amount of information that would be available to a typical insider in the organization.
- In a single-blind test, one side has advanced knowledge; either the attacker has prior knowledge about the target system or the defender has knowledge about the impending attack.
- In a double-blind test, the penetration tester does not have prior information about the system, and the network administrator has no knowledge that the test is being performed. A double-blind test provides more accurate information about the security of the system.

REFERENCES

LabSim for Network Pro, Section 14.2.

Question 10: ✔ Correct

Match each network enumeration technique on the left with its corresponding description on the right.

Identifying phone numbers with modems

✔ War dialing

Scanning for wireless access points

✔ Wardriving

Identifying operating system type and version number

✔ Banner grabbing

Identifying services that can pass through a firewall

✔ Firewalking

EXPLANATION

Network enumeration (also called network mapping) involves a thorough and systematic discovery of as much of the corporate network as possible. Enumeration methods include:

- Social engineering
- Wardriving (scanning for wireless access points within the organization)
- War dialing (trying to access phone lines that will answer a calling modem)
- Banner grabbing (capturing information transmitted by the remote host including the application type, application version, and even operating system type and version)
- Firewalking (using traceroute techniques to discover which services can pass through a firewall or a router)
- Probing the corporate network with scanning tools, often using the same tools used by hackers, such as SATAN and Nessus
- Monitoring the network (usually performed from a remote site)
- Soliciting host-specific banners to identify the function of a remote host

REFERENCES

LabSim for Network Pro, Section 14.2.

Copyright © 2021 TestOut Corporation All rights reserved.